

CPRE 4310

M04 HW

Assignments will be submitted in PDF format via Canvas.

Please submit your homework online through Canvas. Late homework will not be accepted.

Important: Your submission must be in .pdf format ONLY!

You are not allowed to use AI tools to answer any of the HW questions

1. What is the main difference between machine-executable and macro viruses?

The main difference between machine-executable and macro viruses is that one infects binary executable files (.exe extension) while the other infects software programs such as Microsoft Word/Excel. In simple terms, this means that machine-executable viruses infect files which contain code that can be executed/run, whereas macro viruses infect application files by exploiting the macros that are built into the software programs.

2. What are three broad mechanisms that malware can use to propagate?

Malware uses three broad mechanisms to propagate/spread, they are:

- Virus: software that “infects” executable files and copies itself to other programs, usually specific to hardware and OS (Ex: Macro Virus, Compression Virus)
- Worms: exploits network/software vulnerabilities (Ex: DoS Attack, Code Red, Stuxnet)
- Social Engineering: master of asking non-invasive info to gather info over time, leading to gaining trust and reduce defences of the victim. This method effectively just tricks users into executing or installing some malware (Ex: phishing, spear phishing, whaling)

3. Consider the following fragment:

```
legitimate code
if date is Friday the 13th;
    crash computer();
legitimate code
```

What type of malware is this?

This type of malware is called a Logic Bomb. It has characteristics which resemble a virus that lies dormant and will be activated when certain conditions are met, which in this case is a date. When the date is Friday the 13th the code will call “crash computer()”.

4. Assume you have found a USB memory stick in your work parking area. What threats might this pose to your work computer should you plug the memory stick in and examine its contents? In particular, consider whether each of the malware propagation mechanisms we

discuss could use such a memory stick for transport. What steps could you take to mitigate these threats, and safely determine the contents of the memory stick?

In terms of threats, a USB memory stick could contain malware that may infect the work computer if we were to plug it in to examine the contents. Malware such as worms, trojans, or viruses could use the USB memory stick as a means of transport (to propagate) and could pose a serious security risk especially on a work computer that contains important confidential files. For example, it may infect a device as soon as it is plugged in and may even use autorun exploits or some hidden scripts. It may even contain some form of Social Engineering traps such as files that look like actual work documentation. To mitigate these threats, it would be best to examine such a memory device in a sandbox based environment with autorun disabled and ensure that antivirus is enabled. Additionally, it could also first be examined using Cyber Forensics tools (in read only mode) such as Encase or FTK to ensure the contents will not damage/corrupt any other files or system.

- 5. Suppose while trying to access a collection of short videos on some website, you see a pop-up window stating that you need to install this custom codec to view the videos. What threat might this pose to your computer system if you approve this installation request?**

Such a pop-up would depend on how trusted the website is. Regardless, just to view a video if I am needed to install a custom codec, I would find that to be kind of fishy. I would probably do a quick search of what this codec is and if it is truly needed to view/access the videos.

In terms of threat, installing a custom codec from a pop-up could pose quite a serious malware threat to my computer. Such pop-ups employ social engineering tactics and trick users into downloading software/code that could possibly be a Trojan Horse or even spyware in the form of a genuine software.

Because genuine video players already include the necessary codecs required to view videos, it makes it much more suspicious why this website would need me to download a custom one.

- 6. Suppose you have a new smartphone and are excited about the range of apps available for it. You read about an exciting new game that is available for your phone. You do a quick Web search for it, and see that a version is available from one of the free marketplaces. When you download and start to install this app, you are asked to approve the access permissions granted to it. You see that it wants permission to "Send SMS messages" and to "Access your address book". Should you be suspicious that a game wants these types of permissions? What threat might the app pose to your smartphone, should you grant these permissions and proceed to install it? What types of malware might it be?**

At first, I would not think much of the permission to "Send SMS messages" and to "Access your address book" because it is a game and could need those permissions to send requests/invites to friends. Most games these days need such permissions nowadays so that it is easy for a user to send requests to their friends to join games together.

However, since the game was installed from one of the free marketplaces, this could mean that it is not a genuine copy. That being said, such an app installed from non-authorized stores could

pose a serious threat as they may be a form of Trojan Horse malware. If a Trojan Horse malware is given the permissions to send SMS messages and access address book for the user, it could try to send invites to their friends, which the user's friends will be more inclined to install since it was sent by a friend. Such malware could spread rapidly and even send out requests for friends to join the game without the user's permission once the permission has been granted.

7. Why do many DoS attacks use packets with spoofed source addresses?

DoS attacks use packets with spoofed source addresses because this not only hides the attacker's identity, but also makes it harder for the target or security teams to track down the origin of the attack. For example, in reflection/amplification attacks, the attacker uses the target machine's IP address as his own source address (spoofed), then the other devices will send responses to the target machine's IP address. This amplifies the traffic being sent to the target which cause a bottleneck on the target's machine/router because it would not be able to handle so many requests from different machines. Furthermore, the target would be confused why he is getting so many replies when he has not sent out any requests at all using his IP address.

8. What is the primary defense against many DoS attacks, and where is it implemented?

The primary defence for DoS attacks is to filter packets at routers. For defences specific to Classic DoS (TCP/SYN Flood) we need to use SYN cookies and for Simple Ping Flooding Attacks we need to ask ISP's to block ping (ICMP) packets or we can send ICMP responses back to the attacker which will degrade their performance.

For many DoS attacks, called DDoS, we need to implement our routers to block directed broadcast traffic from outside our network (for amplification based attacks), rate limiting in switches, and implementing firewalls. Furthermore, we can follow Prevention, Detection and Response methods which include allocating backup resources and modifying protocols, still being able to provide services when under DDoS attacks, quickly detecting and responding, looking for patterns in traffic, and identifying attackers to take legal/technical action against them.

9. In order to implement the classic DoS flood attack, the attacker must generate s a sufficiently large volume of packets to exceed the capacity of the link to the target organization. Consider an attack using ICMP echo request (ping) packets that are 500 bytes in size (ignoring framing overhead). How many of these packets per second must the attacker send to flood a target organization using a 9.5-Mbps link? How many per second if the attacker uses a 2-Mbps link? Or a 10-Mbps link?

Calculation:

Using packets that are 500 bytes in size:

$$9.5 \text{ Mbps} = 9.5 * 10^6 = 9,500,000 \text{ bits per second}$$

$$500 \text{ bytes} = 500 * 8 = 4000 \text{ bits}$$

$$\frac{9,500,000}{4000} = 2375$$

∴ 2,375 minimum packets/s needed to flood target organization

Using 2 – Mbps link:

$$2 \text{ Mbps} = 2 * 10^6 = 2,000,000 \text{ bits per second}$$

$$\frac{2,000,000}{4000} = 500$$

∴ 500 maximum packets/s

Not going to be able to flood the target organization in this case

Using 10 – Mbps link:

$$10 \text{ Mbps} = 10 * 10^6 = 10,000,000 \text{ bits per second}$$

$$\frac{10,000,000}{4000} = 2500$$

∴ 2,500 maximum packets/s

Able to flood the target organization in this case